

Assignment (01) — Model Answers

Question 1.1 [20 Points] — CIA Triad for Student Information System (SIS)

The Student Information System (SIS) uses a university student number (USN) and a physical/digital card for account access. Below are **two examples for each component** of the CIA triad, along with the degree of importance of each requirement.

Requirement	Example	Importance
Confidentiality 1	Students' personal records (grades, GPA, financial aid status, personal contact details) must be accessible <i>only</i> to authorised users (the student themselves, assigned academic advisors, and registrar staff). Disclosure to any unauthorised party violates students' privacy and may breach regulations such as FERPA.	HIGH — personally identifiable information; legal obligations apply.
Confidentiality 2	The USN and card credentials (authentication data) stored and transmitted by the system must not be exposed. Leakage of these credentials would allow an attacker to impersonate the student and access or manipulate all associated records.	HIGH — credential exposure enables identity theft and full account takeover.
Integrity 1	Academic records (grades, attendance, completed credits) must be protected from unauthorised modification. A student or external attacker altering grades undermines academic fairness and the institution's credibility.	HIGH — directly affects graduation eligibility, scholarships, and honour.
Integrity 2	Financial transaction records (tuition payments, outstanding fees) within the SIS must be accurate and tamper-proof. Falsification of payment records could result in financial fraud or unlawful denial of services.	HIGH — financial integrity has direct legal and operational implications.

Requirement	Example	Importance
Availability 1	The SIS must remain accessible during critical academic periods (course registration, exam result release, fee payment deadlines). Downtime during these windows prevents students and staff from completing time-sensitive tasks.	HIGH — outages during peak periods cause significant academic and administrative disruption.
Availability 2	The card-based authentication service must be continuously available so that authorised users can log in at any time. If the authentication service fails, legitimate users are locked out of the system entirely.	MODERATE-HIGH — brief maintenance windows may be tolerated outside peak periods, but prolonged outages are unacceptable.

Question 1.2 [20 Points] — Fail-Safe Defaults

(a) Security Flaw

The code checks *exclusively* for the value **ERROR_ACCESS_DENIED** and treats *every other return value* as a successful security check. This means that if `IsAccessAllowed()` returns *any* error code other than `ERROR_ACCESS_DENIED` — for example, `ERROR_FILE_NOT_FOUND`, `ERROR_INVALID_HANDLE`, a network time-out code, or any unexpected runtime error — the code falls through to the *else* branch and **grants access**.

This violates the **Fail-Safe Defaults** security design principle, which states that access decisions should be based on *explicit permission* rather than the absence of an explicit denial. The safe default is to **deny access** unless access is explicitly and unambiguously granted.

(b) Corrected Code

The fix is to check for the *success* condition only, and deny access in all other cases:

```
DWORD dwRet = IsAccessAllowed(...);

if (dwRet == ERROR_SUCCESS) {
    // Security check explicitly passed.
    // Grant access to the resource.
} else {
    // Security check failed OR an unexpected error occurred.
    // Fail-safe default: DENY access.
    // Inform user that access is denied.
}
```

Note: By checking for `ERROR_SUCCESS` (the only acceptable grant condition), any unexpected error, new error code, or future change to the API will default to **denial** rather than inadvertent access — fully

honouring the Fail-Safe Defaults principle.

Question 1.3 [10 Points] — Attack Tree: Gaining Access to a Physical Safe

The root node represents the attacker's goal. Each branch represents an approach; OR-nodes mean any child suffices, AND-nodes require all children.

Level	Node / Goal	Type
ROOT	Gain Access to Contents of Physical Safe	OR
L1-A	Open the safe via legitimate means (know credentials)	OR
L2-A1	Obtain the combination / PIN	OR
L3-A1a	[LEAF] Shoulder-surf / observe owner entering combination	—
L3-A1b	[LEAF] Steal written copy of combination (e.g., sticky note)	—
L3-A1c	[LEAF] Coerce or threaten owner to reveal combination	—
L3-A1d	[LEAF] Social-engineer locksmith/manufacturer for combination	—
L2-A2	Obtain the physical key	OR
L3-A2a	[LEAF] Steal the physical key from owner	—
L3-A2b	[LEAF] Duplicate key while owner is unaware	—
L1-B	Bypass / break into the safe by force	OR
L2-B1	[LEAF] Drill or cut through safe body with tools	—
L2-B2	[LEAF] Pick or manipulate the combination lock	—
L2-B3	[LEAF] Use explosives / thermite to open safe	—
L1-C	Remove safe and open elsewhere	AND
L2-C1	[LEAF] Gain physical access to the location	—
L2-C2	[LEAF] Transport safe to a controlled environment	—
L2-C3	[LEAF] Open safe without time pressure using specialist equipment	—
L1-D	Impersonate authorised person / locksmith to open safe	OR
L2-D1	[LEAF] Pose as certified locksmith for 'maintenance'	—
L2-D2	[LEAF] Pose as fire marshal requiring inspection	—

Question 1.4 [15 Points] — Attack Tree: Disclosure of Proprietary Secrets

The company operates two buildings on a fenced property with a guarded front gate. The network has a Headquarters LAN, a Network Services LAN, a Web server behind a firewall (Internet-facing), and a Dial-up server on the Network Services LAN. The attack tree below includes **physical, social-engineering, and technical** attacks with both AND-nodes and OR-nodes, and contains **at least 15 leaf nodes**.

ID	Node / Goal	Type	Category
ROOT	Disclosure of Proprietary Secrets	OR	—
1	Physical Attack	OR	Physical
1.1	Breach the perimeter fence	OR	Physical
1.1.1	[LEAF] Cut or climb the perimeter fence	—	Physical
1.1.2	[LEAF] Tailgate a legitimate vehicle through the guarded gate	—	Physical
1.1.3	[LEAF] Bribe or coerce the gate guard	—	Physical
1.2	Access proprietary documents once inside	AND	Physical
1.2.1	[LEAF] Break into headquarters office (pick lock / force door)	—	Physical
1.2.2	[LEAF] Search waste bins / dumpster for discarded documents	—	Physical
1.2.3	[LEAF] Install a hardware keylogger on an employee workstation	—	Physical
1.2.4	[LEAF] Steal a laptop or printed documents from unattended desk	—	Physical
2	Social Engineering Attack	OR	Social Engineering
2.1	[LEAF] Send phishing / spear-phishing email to employee to harvest credentials	—	Social Engineering
2.2	[LEAF] Pretexting: impersonate IT support to obtain password over phone	—	Social Engineering
2.3	[LEAF] Shoulder-surf employee entering credentials or viewing confidential screen	—	Social Engineering
2.4	[LEAF] Bribe or recruit a trusted insider to exfiltrate secrets	—	Social Engineering
2.5	[LEAF] Leave USB drop (baiting) in company car park for employee to plug in	—	Social Engineering
3	Technical Attack	OR	Technical

ID	Node / Goal	Type	Category
3.1	Attack the Internet-facing Web Server	AND	Technical
3.1.1	[LEAF] Identify exploitable vulnerability in web-server software (reconnaissance)	—	Technical
3.1.2	[LEAF] Exploit web-server vulnerability to gain shell access	—	Technical
3.1.3	[LEAF] Pivot from web server to internal Network Services LAN	—	Technical
3.2	Attack via Dial-up Server	OR	Technical
3.2.1	[LEAF] War-dialling to enumerate the dial-up access number	—	Technical
3.2.2	[LEAF] Brute-force or dictionary attack on dial-up authentication credentials	—	Technical
3.3	Attack the Firewall	OR	Technical
3.3.1	[LEAF] Exploit misconfiguration or known vulnerability in the firewall	—	Technical
3.3.2	[LEAF] Conduct SQL injection on the web application to exfiltrate backend data	—	Technical
3.4	Intercept Internal Network Traffic	AND	Technical
3.4.1	[LEAF] Gain access to the internal Headquarters LAN	—	Technical
3.4.2	[LEAF] Perform passive sniffing / ARP poisoning to capture traffic	—	Technical

Note: The tree has 20 leaf nodes, well exceeding the required minimum of 15. All three attack categories (physical, social engineering, technical) are represented, and both AND-nodes and OR-nodes are used.

Question 1.5 [15 Points] — Security Incident Terminology

Scenario recap: An attacker exploits a *known software bug* in the company's web server, gains unauthorised access, and then *deletes all product databases*.

Par t	Term	Answer
(a)	Primary Asset(s)	Data asset — the product databases (the core information resource that was targeted and destroyed). Software asset — the web-server software and the underlying database management system that stores and serves the product data.

Part	Term	Answer
(b)	Vulnerability	The known, unpatched software bug in the web server. This is a weakness in the system's software implementation that could be (and was) exploited by a threat agent. The fact that the bug was already known but not remediated (i.e., the patch was not applied) compounded the vulnerability.
(c)	Threat	The potential for an external attacker (threat agent / adversary) to exploit vulnerabilities in the web server, resulting in unauthorised access to and destruction of the company's data assets. More specifically, the threat consequence here is Disruption (loss of Availability and Integrity), realised through the threat action of Corruption (deletion of the database).
(d)	Attack Category &	Attack: Exploitation of the known web-server vulnerability to obtain unauthorised remote access, followed by the deliberate deletion of all product databases. Category: • Active attack — the attacker altered and destroyed system resources (product data), which is the hallmark of an active attack (as opposed to a passive reconnaissance attack). • Outsider / External attack — the attacker originated from outside the company's security perimeter.
(e)	Countermeasure & Category	Primary Countermeasure — Patch Management (Timely Software Updates): Applying the available patch to fix the known vulnerability <i>before</i> it was exploited would have prevented the attack entirely. • Function: Technical (software-based control). • Type: Preventive (intended to stop the incident from occurring). Secondary Countermeasure — Regular Database Backups: Maintaining up-to-date, off-site backups of the product databases would have enabled rapid recovery of the deleted data. • Function: Technical. • Type: Recovery (restores the environment to normal operations after the incident).